

ACME Persistent DNS Challenge

draft-ietf-acme-dns-persist

A long-lived DNS TXT record, carrying an `accounturi` and a `persistUntil` expiry, authorizes one CA account to issue for a domain with no action needed at each issuance.

Shiloh Heurich (Fastly)

Henry Birge-Lee (Crosslayer Labs)

Michael Slaughter (Amazon Trust Services)

IETF 126 ACME WG — Vienna

Since IETF 125: From Alternatives to PR #67

Security guidance corrected

- **PR #66 merged:** the CA-side DNSSEC guidance now protects the **ACME directory URL**, the name clients resolve and connect to; `issuer-domain-name` is an opaque identifier inside the record

Three approaches to substitution hardening (#64)

PR	Approach	Outcome
#62	Authenticated POST to supplied <code>accounturi</code>	Closed: requires a live endpoint and online client
#65	<code>pubkey:</code> hash of the account key	Closed: new wire format; DNS update on rollover
#67	Hash name + key + account URL	Selected (open draft): offline binding with rollover continuity

Goal: restore non-transferability; keep offline provisioning and rollover.

The Substitution Gap (Issue #64)

The property at risk

Non-transferability: a validation by an honest domain owner must not become authorization for a *different* account at an honest CA.

RFC 8555 preserves this by binding the account key into the challenge response, computed offline by both sides (§8.1, §10.2).

Why mode 3a (raw URL) fails

The record carries only a server-provided `accounturi`.

A malicious, compromised, or impersonated ACME endpoint poisons the client's own account URL at creation; the CA's later byte-for-byte Simple String Comparison passes against it.

The victim publishes a record authorizing the **attacker's** account.

Framing: the property at stake is non-transferability, not "protection after trusting a bad server".

PR #67: Offline Binding with Account Continuity

The client and CA independently construct the same hashed `accounturi` :

```
<accountHashPrefix><hash-alg>/<base64url hash value>  
H(length_of_domain || domain_name || key || account_URL)
```

Example:

```
_validation-persist.example.com. IN TXT "example.ca accounturi=https://example.ca/acme/hash/sha-256/47DEQpj8HBSa..."
```

- `domain_name` prevents cross-name reuse; `key` supplies the client-computed proof
- `account_URL` binds the value to one account; the 1-octet length plus the fixed-length `key` make every field boundary unambiguous
- `sha-256` identifies SHA-256 (`H`); future algorithms use different tokens
- The CA **recomputes** and string-compares; prior-key matching supports rollover continuity
- `accountHashPrefix` (new directory `meta` field) lets the client build the URI without another request

Why this design: a poisoned value fails validation instead of transferring authorization, without requiring a live account endpoint or a public-key URI scheme.

Mandatory Hashed-URI Binding

The post-`-01` working copy grew three `accounturi` modes. The current `-02` direction **collapses them to one**:

Working mode	<code>accounturi</code>	<code>-02</code> disposition
3a	ACME account URL (raw)	Dropped: leaves the substitution gap open
3b	Alternative CA-assigned URI	Redefined: the client-computed hashed URI is the sole form
3c	Subscriber-account URI (many)	Dropped: remains available under CA/B Forum BR 3.2.2.4.22 and CA policy (CP/CPS)

No raw-URL downgrade.

Ask: any WG objection before we publish `-02` along these lines?

Final Construction Review

Settled in review

- Exact recomputation over a fixed field structure makes length extension irrelevant
- `account_URL` provides RFC 8657 §5.4 uniqueness; the record's FQDN adds per-name privacy and prevents cross-name reuse

Interoperability edits before -02

- Use the unpadded base64url RFC 7638 thumbprint ACME libraries already produce
- Make `sha-256` mandatory; future tokens come from the RFC 6920 registry (non-truncated, at least 256 bits)
- Bound prior-key acceptance by time without adding a client key hint

Privacy limit

HTTP-01 exposes the account-key thumbprint on the CA's cleartext validation fetch; hashing is best-effort anti-correlation, not strong unlinkability.

What Lands in -02 , and Why

Land now: author-settled and scoped

- **#38**: avoid provisioning an already-expired record
- **#42**: keep DNS cache lifetime separate from authorization lifetime
- **#56**: align the challenge object with ACME JSON naming
- **#60**: discover issuer names before creating an order

Defer past -02

- **#32** IP validation: defer to keep this revision focused
- **#33** subdomains: choose RFC 9444 reuse or a new signal
- **#39** errors: decide whether to register challenge-specific errors
- Close **#59/#64** after #67; keep **#61** open for privacy

Path Forward

Settled fixes in the -02 candidate

- Rotation-text rewrite, RFC 8657 clarification, base64url thumbprint with new vectors
- RFC 6920 hash tokens (mandatory `sha-256`), HTTP-01 privacy caveat, issues #38/#42/#56/#60
- IANA early review requested for the new directory metadata

Two remaining questions: exact proposals under author review

- `keyRolloverWindow` would replace `keyRotationPeriod`: required directory field; exact acceptance window after a key rotates out; record removal, `persistUntil`, and deactivation end it sooner; certificate validity does not extend it
- **Keep** `domain_name = "*" (client MAY / CA MUST)`: a DNS observer can link the account's domains; records evaluate independently, with no precedence rule

Submission blackout: gather feedback Thursday, confirm on-list, then publish -02 .

Room ask: input or objections on the two pending proposals?

Questions & Discussion

- Any objection to dropping 3a and 3c and making the hashed URI mandatory?
- Input on the proposed `keyRolloverWindow` semantics?
- Keep the domain-omitted `*` form (client MAY / CA MUST)?

Parallel CA/Browser Forum work (BR Method 3.2.2.4.22):

[#674](#) one-to-many `accounturis` · [#675](#) parameter-key case-sensitivity

[#676](#) `policy=wildcard` · [#677](#) separate validation method for dns-persist-01

Mailing list: acme@ietf.org

GitHub: <https://github.com/ietf-wg-acme/draft-ietf-acme-dns-persist>

Draft: <https://datatracker.ietf.org/doc/draft-ietf-acme-dns-persist/>